

Reflection Question / Answers

1. Explain the difference between authentication & authorization.

Ans: Authentication & authorization are two essential security processes that work together to protect a system.

Authentication: Authentication is the first step, where a user's identity is verified by checking credentials such as a username & password. Only after successful authentication is the user allowed to access the application.

Authorization: Authorization comes after authentication & determines what actions or resources the authenticated user is permitted to access. In my chat application, authentication ensures that only registered users can log in, while authorization allows them to send messages, view online users, & use available chat features. Together, these mechanisms enhance security, protect user data, & prevent unauthorized access to the application.

2. Why should passwords never be stored in plain text?

Passwords should never be stored in plain text because doing so creates a serious security risk. If an attacker gains access to the user database, every password becomes immediately visible, allowing unauthorized access to user accounts & other services where the same password may have ~~may~~ been reused. This can lead to identity theft, data breaches, & loss of user trust.

To avoid these risks, passwords should always be stored in a hashed format using secure algorithms such as SHA-256. Hashing converts passwords into unreadable values that cannot easily be reversed, ensuring that even if the database is compromised, the original ~~data~~ passwords remain protected & confidential.

3. What is the purpose of password hashing?

The primary purpose of password hashing is to protect user credentials by converting passwords into unique, fixed-length hash values before storing them in the database. Unlike encryption, hashing is a one-way process, meaning the original password cannot be easily recovered from its hash. Whenever a user logs in, the entered password is hashed again & compared with the stored hash. If both values match, authentication is successful without exposing the actual password.

Date _____
Page _____

4. How does duplicate login prevention improve security?

Duplicate login prevention is a important security feature that allows only one active session for user account at a time. if someone attempts to log in using the same username while the account is already active, the server denies the second login request. This prevents unauthorized users from accessing another person's account & discourages account sharing. It also protects users from accidentally using the same account on multiple devices simultaneously, reducing confusion & maintaining proper session management.

5. Suggest two additional security improvements for your application.

Two additional security improvements can further strengthen the chat application.

First, SSL/TLS encryption can be implemented to encrypt all communication between the client & server, prevent attackers from reading usernames, passwords or messages during transmission.

Second, two-factor authentication (2FA) can be added to require users to verify their identity using a one-time password sent to their email or mobile device after entering the correct password.

These improvements provide multiple layers of protection against unauthorized access, enhance user privacy, & make the application more secure against common cyber threats & network-based attacks.